

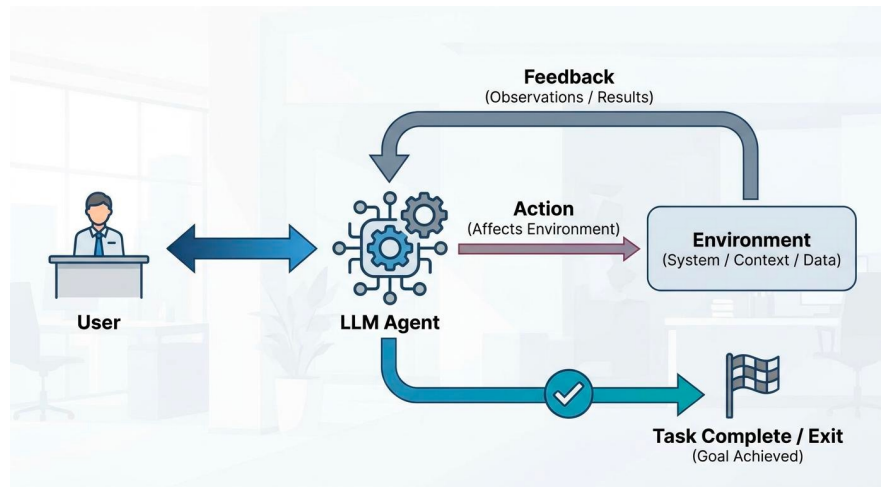


面向Agentic AI的开源项目的合规考量



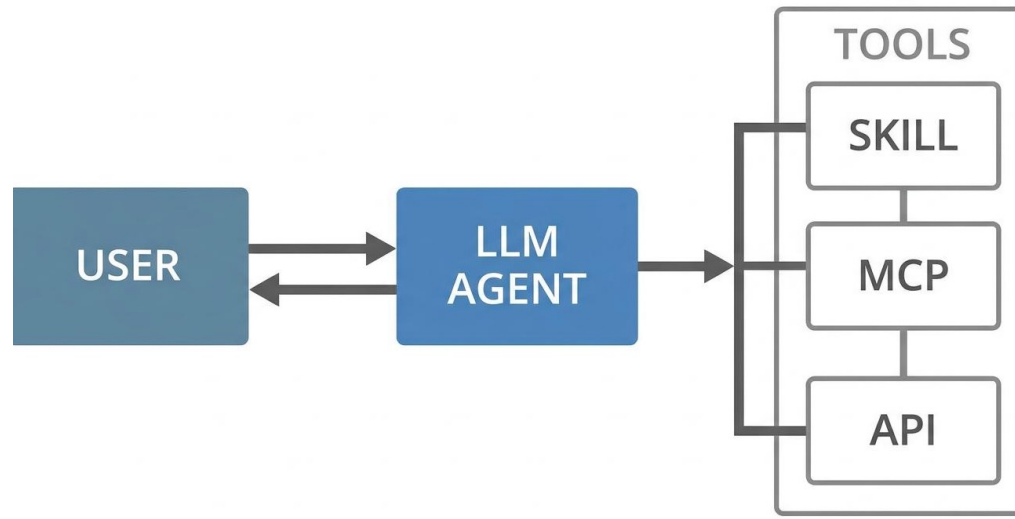
概念及特点

Agentic AI



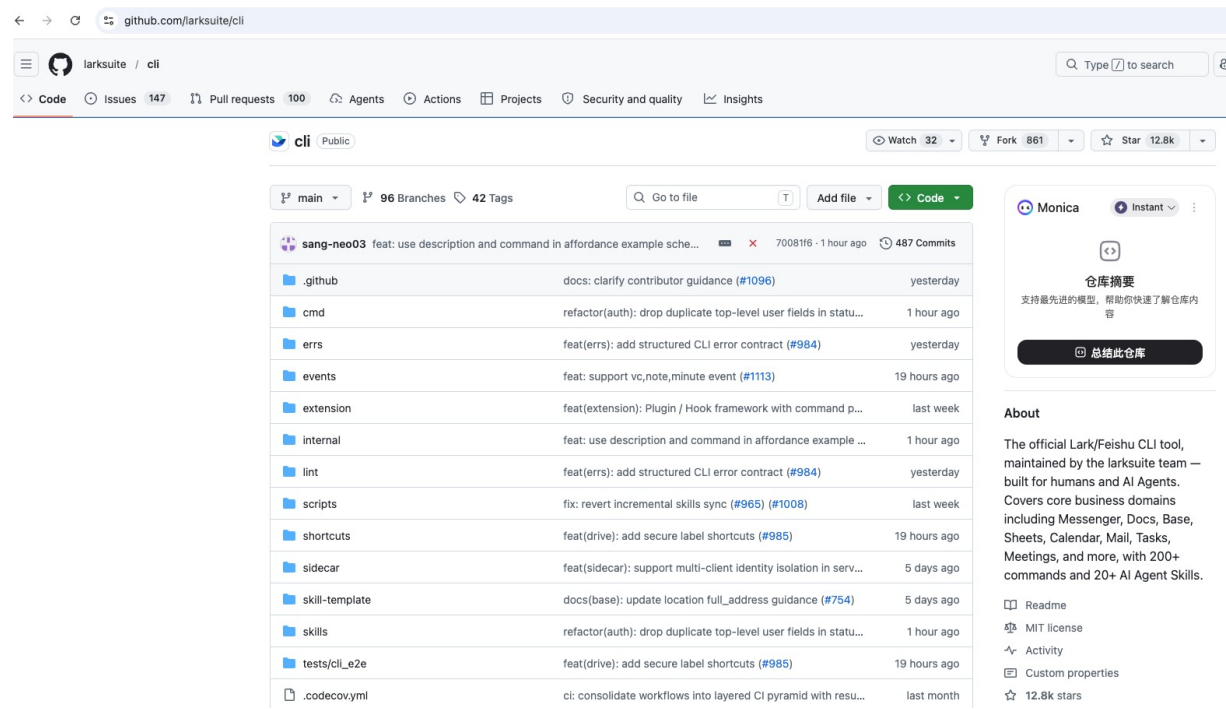
Agentic AI是一种人工智能系统，可以在有限的监督下完成特定目标。它由AI agent-机器学习模型组成，模仿人类决策实时解决问题。与一般的生成式模型不同，Agentic AI表现出自主性、目标驱动的行为和适应性。术语“Agentic”指的是这些模型的代理，或者它们独立和有目的地行动的能力。

Agentic AI架构



在执行一些复杂的任务时，LLM Agent通常需要调用一些工具，包括Skill、MCP/API以及其他一些tools。

面向Agentic AI的开源项目案例



为了方便用户通过LLM Agent自动地使用飞书服务，飞书开发并开源了对应的CLI工具以及对应的skill

面向Agentic AI的开源项目的特点

	开源代码	面向Agentic AI的开源项目
包含的材料	主要是代码;自然语言描述的文档为附属材料，通常不会被使用；少量项目可能包括字体文件、ICON等素材	包括自然语言描述的指令(Prompt)；可能包括代码，也可能包括字体文件、ICON、图片、音视频素材等
项目的受众	通常是下游的开发者	终端用户，包括很多技术小白
项目属性	源码本身不是产品和服务，一般认为是产品供应链的一部分	项目的完整度较高，形态上更接近于终端产品/服务
远程服务	大部分开源项目本身不会调用远程API和MCP	除了所必须依赖的LLM API之外，一些项目还会调用其他API、MCP等远程服务

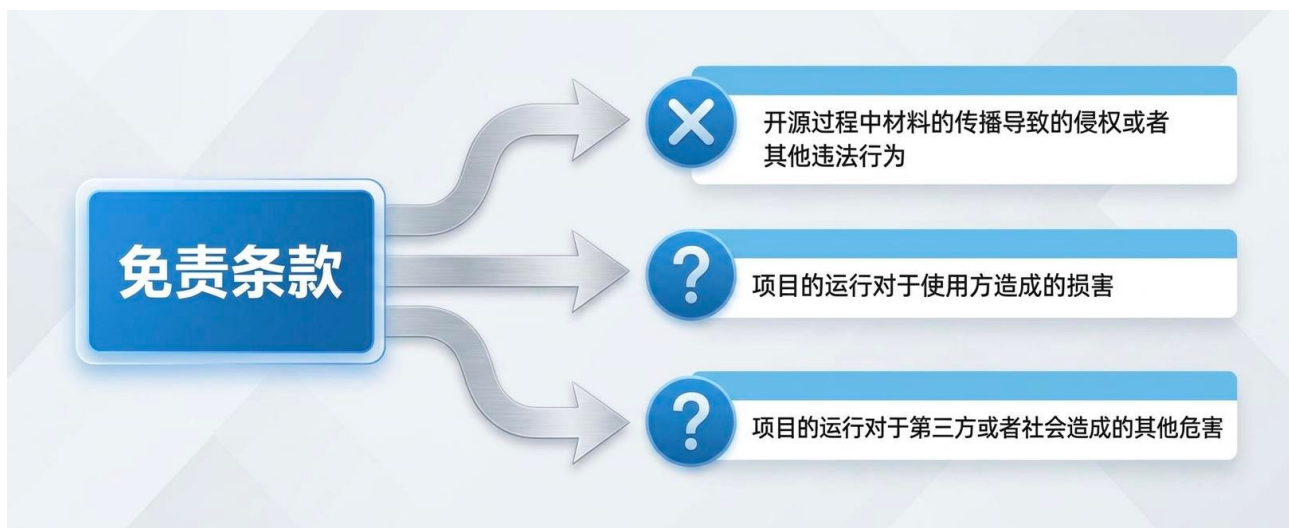


合规考量

开源过程中的合规目标

避免知识产权的不当流失	避免因为开源给公司带来风险
开源的范围适当; 选择合适的许可证; 合理的知识产权保护	避免侵权; 避免舆情风险; 避免违约/违反许可证; 避免违反监管要求

免责条款的效力



朱中华 2130

合规要求-知识产权与不正当竞争

合规项	合规要求/标准
代码许可证合规	如果项目中包含代码（比如脚本），则需要检查代码以及其所引用依赖的许可证，遵循许可要求
内置素材的合规检查	受版权保护的第三方素材（字体文件、图片、视频、音频、文档、知识库等），针对各素材是否有对应许可证，或者权利声明；不得侵犯第三方的商标权利
Prompt本身的许可证合规	如果自然语言指令是基于三方skill等项目得到，则需要同时遵守skill的许可证
Prompt的诱导侵权排查	排查 Skill 的系统提示词（System Prompt）或预置指令中，是否存在引导大模型复刻、抄袭或模仿第三方受版权保护内容或生成社交媒体网站风格的内容（比如小红书风格内容

合规要求-知识产权与不正当竞争

合规项	要求
联网抓取能力合规	1. 明确 Skill 是否具备主动联网搜索及抓取内容的能力，以及抓取的内容类型（文字、图片、视频）； 2. 抓取行为必须遵守目标网站的 robots.txt 协议； 3. 严禁利用技术手段绕过或破坏目标网站和/或谷歌等搜索引擎的技术保护措施（如绕过登录鉴权、抓取付费内容等）。
许可证选择	1.选择的许可证应与其开源目的匹配； 2.许可证的类型与所开源的材料类型匹配 3.不应该出现许可证兼容性冲突；

合规要求-数据安全与隐私

项目	合规要求/标准
数据外传管控	1. Skill 不得将用户输入、文档内容或处理中间结果发送到非必要的外部服务（含第三方分析/监控平台）； 2. 如需外传数据，须在文档中明确说明并获得用户知情同意
数据脱敏处理	1. 处理涉及用户信息（姓名、邮箱、工号等）的数据时，日志、缓存或返回结果中须做脱敏处理
临时数据安全存储	1. 敏感中间数据写入临时目录时须设置合适文件权限，并在处理完成后及时清理
后台静默行为监控	1.非用户调用情况下，Skill不得后台静默处理用户数据，例如静默读取用户浏览器密码
数据处理合规	1. Skill 实际访问/处理的数据处理活动与其声明的数据处理活动一致

合规要求-敏感信息

项目	合规要求/标准
硬编码凭证检测	1. 代码或配置文件中不得包含明文的 API Key、Access Token、数据库密码、Webhook URL 等敏感凭证
内部域名/端点暴露	1. Skill 代码或描述中不得硬编码内部服务域名、内网 IP、内部 API 路径
调试信息残留	1. 不得在生产代码中保留输出敏感上下文的日志语句（如完整请求头、认证 Token、用户输入原文）而无条件门控
敏感文件打包	1. Skill 分发包内不得包含 .env、.git/config、id_rsa、kubeconfig、credentials.json、.npmrc（含 token）等敏感文件

合规要求-技术安全

项目	合规要求/标准
权限与访问控制	Skill 只能拥有和使用完成其功能所必须的最小权限，不得通过系统调用执行未校验的外部输入，不得访问功能范围外的敏感目录，文件操作路径须防止穿越。
代码安全质量	Skill 代码须防范常见安全漏洞——外部输入不得直接拼接到 SQL/命令/URL 中，不得用不安全方式处理不可信数据（如 eval、pickle），异常不能暴露堆栈，加密须用安全算法，网络通信须走 HTTPS 且不禁用证书验证
依赖与供应链安全	Skill 引入的第三方依赖不得含高危已知漏洞，版本须锁定（不用 *、latest），依赖数量须与功能匹配不过度引入，且不得使用超 长期未更新或已废弃的库。
提示词安全	Skill 的 Prompt 不得包含诱导 Agent 越权操作、泄露数据或绕过安全策略的指令，也不得通过 Prompt 让 Agent 改变默认安全行为（如跳过确认、隐瞒操作）。

合规要求-内容合规

项目	合规要求/标准
内容合规	不得包括色情、血腥、歧视等违禁词汇或者描述； 不应包含用户的个人信息，比如昵称、邮箱地址、电话、肖像等；

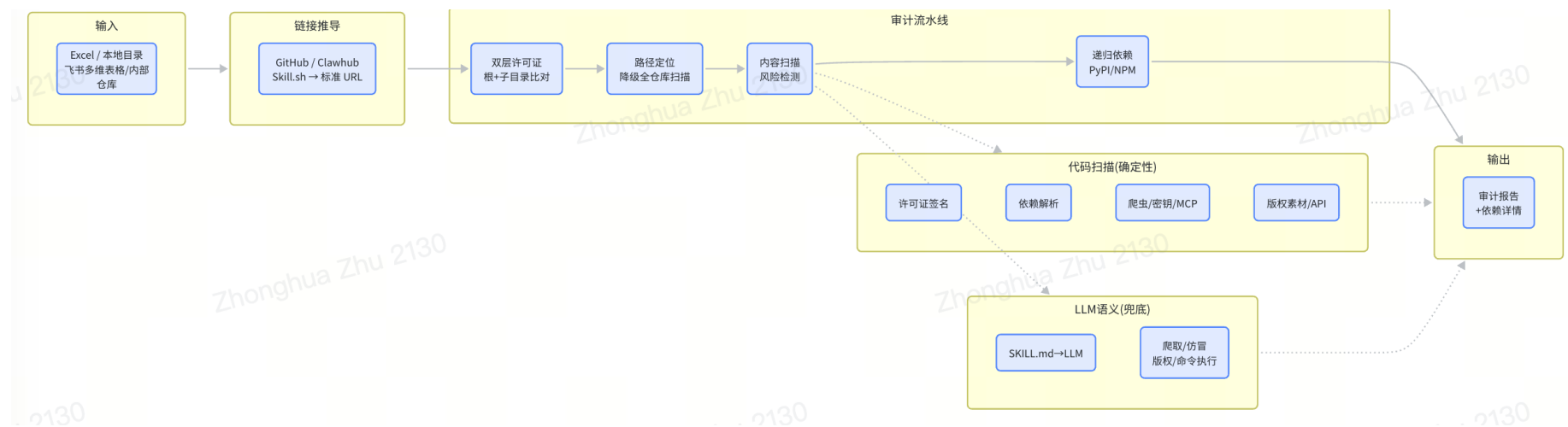


合规实践探索

自查清单

检查项	检查内容 (请选择)
是否经过安全BP检查	☐ 是 ☐ 否
是否会爬取特定网站内容	☐ 是, 会指示模型/通过脚本抓取/读取如下网站的信息; ☐ 否, 不涉及
API检查	Skills是否需要调用指定的API ☐ 是, 请说明调用的API链接以及用途: _____ ☐ 否, skills的运行仅需要LLM API, 且不限于特定的LLM
敏感信息扫描	当前的敏感信息扫描是否已经覆盖了skills中的各个文档 ☐ 否, 仅对代码进行了扫描 ☐ 是, 代码文件以及各个描述文档都已经覆盖
skill是否包含代码脚本	☐ 是, 且已经完成开源代码扫描, 扫描链接是: ☐ 否, 请完成开源扫描

审计工具





行动建议

合规标准



针对Skill这类面向Agentic AI
的开源项目形成新的合规标准
， 或者迭代OpenChain以覆盖
Skill类软件

工具建设



建设针对自然语言指令以及版权素材的扫描能力和检测能力



THANKS!